

TBD2

Enterprise Risk Monitoring Platform

Strategic Analysis & Technical Validation Report

CONFIDENTIAL — INTERNAL USE ONLY

Prepared by: Senior Product Analyst

April 2026 | Version 1.0

Audience: Team

1. Executive Overview

This report does three things: (1) validates or challenges every technology and architecture choice in the PRD v1.2, line by line, against current research; (2) conducts a full SWOT analysis of the platform and its market position; and (3) identifies the most commercially valuable customer segments with evidence-based sizing. Every claim is sourced.

Bottom line up front: The product concept is strong and well-timed. The ERM market is growing at 14.8% CAGR and is projected to reach \$11.97B by 2030. Only 21% of organisations currently use dedicated GRC platforms and 59% still run on spreadsheets, this is a wide-open opportunity. The technology stack chosen in the PRD is largely sound, but three specific decisions need to be revisited before Week 1 coding begins: the choice of React SPA over Next.js, the use of Django as a co-equal option alongside FastAPI, and the lack of a real-time push mechanism. These are detailed below.

2. Market Context & Opportunity

2.1 Market Size (Verified)

Multiple research firms converge on the following picture for the Enterprise Risk Management (ERM) and GRC software market:

Source	2025 Value	2030 / 2035 Projection	CAGR
MarketsandMarkets (Feb 2026)	\$6.00B	\$11.97B (2030)	14.8%
Global Growth Insights	\$5.94B	\$11.21B (2035)	6.55%
The Business Research Co.	\$5.17B	\$7.76B (2030)	8.6%
Global Insight Services	\$5.60B	\$10.0B (2035)	5.8%
GRC Software (broader)	\$38B (2024)	\$138B (2030)	15.4%

Key insight: Even at the conservative end (6.55% CAGR), this is a \$10B+ market by 2035. The GRC software segment, which includes this platform, is growing at 15.4% CAGR and is already a \$38B market. The AI-specific sub-segment is the fastest growing. Only 6% of organisations currently use AI to assist in identifying risks (IIA 2025 Enhanced ERM Study). This platform is entering at the inflection point.

2.2 Market Dynamics & Tailwinds

The following structural drivers are confirmed by multiple research sources and directly support the TBD2 product thesis:

- 67% of enterprises are adopting AI analytics in ERM, demand exists and is accelerating
- 59% of organisations still manage ERM on spreadsheets, the displacement opportunity is enormous
- Only 21% have implemented dedicated GRC platforms, the market is underpenetrated
- 74% of organisations are actively investing in AI/GenAI capabilities (Deloitte 2025)
- 72% report increased exposure to operational and cyber risks, urgency is high
- EU AI Act (phased in from August 2025) is creating mandatory AI governance requirements
- Agentic AI risk monitoring (autonomous alerts and remediation) is the direction the market is moving, this platform is building toward it

Critical gap this platform fills: Only 18% of ERM leaders express high confidence in identifying emerging risks (Gartner). Existing platforms are built for governance and compliance, not for AI-driven, real-time, hierarchical risk intelligence. This is the specific white space TBD2 is targeting.

3. Competitive Landscape

3.1 Direct Competitors

The following are the confirmed primary ERM/GRC competitors as of 2026, with their known weaknesses that TBD2 can exploit:

Platform	Target Segment	Key Strength	Key Weakness / Gap
MetricStream	Large enterprise	Broad GRC + AI (AiSPIRE engine)	Heavy implementation (months + consultants), dated UI, expensive
Riskconnect	Mid to large enterprise	Widest risk spectrum, insurance origins	No standout AI narrative, UI criticised
Logic Manager	Mid-market	Fixed pricing, advisory support	Limited API integrations, slow reporting, no real AI correlation engine
Diligent One	Board / executives	Board-ready reporting, NLP risk scanning	Narrow ERM depth, steep learning curve, high pricing
RSA Archer	Large enterprise	Deep configurability, legacy market share	Complex maintenance, dated interface, slow implementation
ServiceNow GRC	IT-heavy enterprises	Strong ITSM integration	Overkill for non-IT risk, very high cost, locked to ServiceNow
Logic Gate Risk Cloud	Mid-market	Pre-built templates, no-code	Less deep than enterprise platforms, limited AI capability
IBM OpenPages	Financial services	Regulatory depth, IBM ecosystem	Very expensive, requires IBM infrastructure commitment

3.2 TBD2 Differentiation

Against this landscape, TBD2 has a defensible differentiation position on three axes:

- Two-tier LLM processing with intra-module correlation analysis, no competitor has this as a native first-class feature. Existing platforms offer AI as a reporting add-on, not as the analytical engine at every hierarchy level.
- Five-level drill-down hierarchy (Enterprise > Module > Sub-Module > Group > Metric), competitors offer top-level dashboards and some drill-down, but none have a structured 1,200+ metric hierarchy with AI correlation at each tier.
- Investor-grade PDF/PPT export from AI-synthesised data, positioned explicitly for CRO/CFO stakeholder presentations. No competitor makes this a first-class feature.
- Modern, executive-grade UI (TBD2 / Aegis Quantum design system), MetricStream and Archer are frequently criticised for dated interfaces. The premium dark-mode HUD aesthetic is a genuine differentiator in this market.

4. SWOT Analysis

This SWOT is grounded in the artefact analysis from Section 1, competitive research from Section 3, and market data from Section 2. Every item is evidence-based, not generic.

STRENGTHS
• PoC is already complete, two-tier LLM integration and 12 module pipelines are proven. This is not greenfield; the analytical engine works. • 1,200+ metric hierarchy with AI correlation at every level (Enterprise > Module > Sub-Module > Group > Metric), no competitor offers this architecture natively. • Model-agnostic LLM integration, configurable between Anthropic, OpenAI, and Gemini. Reduces vendor lock-in and allows cost optimisation. • Premium enterprise UI (TBD2 / Aegis Quantum), Space Grotesk + Inter, tonal layering, no-line design system, visually miles ahead of MetricStream and Archer.
• Investor-ready PDF/PPT export feature, directly addresses executive and board communication needs. • Confidence scoring layer on every projection, gives risk outputs statistical credibility, a differentiator in the market.
• Modular, independently deployable pipeline architecture, each of the 12 domain pipelines can be deployed and updated independently. • Small lean team (4 people) with clear role independence model, minimal coordination overhead for an 8-week MVP. • Batch pipeline V1 + real-time in V2 roadmap, pragmatic scope management.

WEAKNESSES

- 12 Modules not yet defined (Open Question Q3) — the exact module list and sub-module/group structure is unresolved. This BLOCKS DB schema design and pipeline wrapper work in Week 1.
- Confidence scoring methodology undefined (Open Question Q6) — the statistical model is unspecified. This will block the confidence engine in Week 5-6.
- No real-time data ingestion in V1.0 — batch pipeline only. Enterprise customers with time-sensitive risk monitoring (telcos, financial services) may find this a barrier.
- Single-tenant V1.0 — multi-tenancy deferred to V2.0. Limits SaaS commercialisation options for the MVP.
- No ERP/ITSM integrations in V1.0 — manual data import only. Creates friction for enterprises already using SAP, ServiceNow, or Oracle.
- React SPA choice has architectural risks at scale (see Section 5 — Tech Stack Analysis).
- Emergency Override button visible in all UI screens but completely unspecced — 10 similar unspecced UI elements identified. These are engineering time bombs.
- LLM API costs at scale — 12 parallel module calls + 1 enterprise call per pipeline run. At enterprise scale with multiple tenants (V2.0), this cost model needs validating.
- No mobile app in V1.0 — responsive web only. Increasingly, executives expect mobile access to dashboards.

OPPORTUNITIES

- ERM market growing at 14.8% CAGR to \$11.97B by 2030 — one of the fastest-growing enterprise software segments.
- 59% of organisations still on spreadsheets for ERM — massive displacement opportunity with zero technical competition.
- EU AI Act (phased in August 2025) creating mandatory AI governance requirements — regulatory tailwind driving urgency to adopt AI risk platforms.
- Only 6% of organisations use AI for risk identification (IIA 2025) — first-mover advantage window is wide open.
- Telecom sector SLA-linked domain monitoring is a high-value vertical — underserved by current competitors whose origins are in financial services.
- V2.0 multi-tenancy unlocks SaaS scaling — one platform serving multiple enterprise tenants dramatically changes the unit economics.
- Agentic AI (autonomous risk monitoring and remediation) is the market's declared next phase — the two-tier LLM architecture is an extensible foundation for this.
- APAC and Middle East & Africa are fastest-growing regions (23% and 10% of global market) — low competition from legacy US/EU incumbents.
- Mid-market and SME segments are underserved by MetricStream and Archer (too expensive, too complex) — significant addressable market at lower price points.

THREATS

- MetricStream AiSPIRE engine is already in market — if they ship strong correlation analysis capabilities, the AI differentiation gap narrows.
- ServiceNow GRC expansion — ServiceNow is aggressively moving into AI-powered risk. Enterprises already on ServiceNow may never evaluate TBD2.
- LLM API cost volatility — OpenAI/Anthropic/Google pricing changes directly impact the product's operating economics. No hedging strategy in the PRD.
- LLM reliability dependency — the entire analytical engine depends on third-party LLM API uptime. A provider outage means no new AI insights.
- 8-week MVP timeline is aggressive — 4 people, 7 screens, two-tier LLM integration, PDF/PPT export, RBAC, admin module. Timeline risk is high.
- 10 unspecced UI elements (Emergency Override, Force Recalc, Deploy New Watcher, Rollback Last Domain etc.) — if these get specced mid-sprint, they will break the delivery timeline.
- Data privacy regulations (GDPR, CCPA, upcoming) — enterprise customers will require data residency options. V1.0 does not address data governance.
- Enterprise sales cycles are long — even a strong MVP may take 6-12 months to close the first paid enterprise customer.
- Pricing model undefined — the PRD has no commercial model. No freemium tier, no pricing tiers, no enterprise contract structure.

5. Technology Stack — Line-by-Line Validation

The PRD recommends a specific technology stack. Each choice is evaluated below against current (2026) research, with a verdict and recommendation for your three-way decision-making process.

5.1 Frontend: React SPA vs Next.js

PRD says: "React.js / Next.js" — listed as options. The design artefacts are pure HTML/Tailwind prototypes, which are framework-agnostic.

Research finding: For this specific product — a fully authenticated, data-dense enterprise dashboard behind a login wall, with no SEO requirements and complex interactive state — the research consensus in 2026 is clear:

Factor	React SPA	Next.js
Performance for dashboards	Excellent for CSR-only SPAs with complex state	Server components add overhead for heavily interactive UIs
Authentication-gated apps	Ideal — no public pages need SSR/SSG	SSR/SSG benefits are wasted when all pages are behind login
Architectural independence	Clean separation: React frontend + FastAPI backend	Introduces Node.js server tier between React and FastAPI
Scalability (UI)	Scale React/Vite independently via CDN/S3	Requires Next.js server instances to scale
Used by similar products	Figma, Notion, Trello, enterprise dashboards	Marketing sites, e-commerce, content platforms
2026 verdict	RECOMMENDED for this use case	Over-engineered for an auth-gated dashboard

Verdict: React SPA (with Vite as the bundler, not CRA) + TailwindCSS is the correct choice for TBD2. Next.js should not be used. The product has no public-facing pages, no SEO requirement, and extremely complex interactive state (1,200+ metrics, drill-down navigation, real-time pipeline status, AI co-pilot). The additional SSR/SSG machinery of Next.js adds complexity without benefit for this architecture. The PRD's "React.js / Next.js" framing should be resolved to React SPA + Vite.

5.2 Backend: FastAPI vs Django REST

PRD says: "Python (FastAPI / Django REST), Celery for async pipelines"

Factor	FastAPI	Django REST
Async/concurrent requests	Native async/await — ideal for LLM API calls	Async requires careful config; not fully async-native
LLM API integration	Handles concurrent LLM calls (12 modules in parallel) natively	Concurrent LLM calls need workarounds
Performance (RPS)	3,000+ RPS — fastest Python framework in benchmarks	Slower due to heavyweight ORM middleware
Auto-generated API docs	Built-in OpenAPI/Swagger — essential for frontend API contract	DRF requires additional setup
RBAC / Admin panel	Must build or use library (FastAPI-Users etc.)	Built-in — significant time saving for Admin module
LLM async relay (Ask AI)	Native — perfect for streaming responses	Workarounds required
Team learning curve	Lower if team knows Python type hints	Lower if team has Django experience
2026 verdict for this product	STRONGLY RECOMMENDED	Not recommended for this use case

Verdict: FastAPI is the clear choice for TBD2. The two-tier LLM architecture — 12 parallel module calls + 1 enterprise call — requires genuine async concurrency, which FastAPI handles natively. The Ask AI relay needs streaming response support. Django's admin panel is its main advantage, but the admin module in this product is custom-specced (RBAC, audit logs, user management) and will need to be built regardless. Used in production by Netflix, Microsoft, and Uber. Resolve the PRD's 'FastAPI / Django REST' to FastAPI only.

5.3 Async Pipeline Orchestration: Celery

PRD says: "Celery for async pipelines, Cron / Celery Beat for scheduling"

Verdict: CONFIRMED CORRECT. Celery is the right tool for the two-tier LLM orchestration problem. The barrier/join pattern — run 12 module pipeline tasks in parallel, wait for all to complete, then trigger the enterprise-level call — maps exactly to Celery's `chord` primitive (group of tasks + callback). Celery Beat for scheduled runs is the standard approach. One important note: use Redis as the Celery broker (already in the PRD stack) rather than RabbitMQ to minimise infrastructure components.

5.4 Database: PostgreSQL + Redis + S3

PRD says: "PostgreSQL, Redis (cache), S3-compatible object storage"

Verdict: CONFIRMED CORRECT. PostgreSQL is the right choice for the five-level hierarchy (a recursive/tree structure that PostgreSQL handles well with CTEs and JSONB). Redis for Celery broker + response caching (LLM output cache per module per run) is correct. S3-compatible storage for PDF/PPT exports and potentially the Module Knowledge Base documents. No changes recommended.

5.5 Infrastructure: Docker + Kubernetes + Celery Beat

PRD says: "Docker / Kubernetes, Cron / Celery Beat"

Verdict: CONFIRMED FOR MVP, but flags a resourcing risk. Docker is essential and non-negotiable. Kubernetes in the 8-week MVP is ambitious — it adds significant DevOps overhead (cluster management, ingress, service mesh, secrets management via Kubernetes Secrets or Vault). A more pragmatic V1.0 approach would be Docker Compose for the initial deployment (reduces Week 1-2 DevOps burden) with a clean migration path to Kubernetes for V1.1 when load testing justifies it. This is a decision for you and your DevOps partner to make together.

5.6 One Missing Component: WebSocket / SSE for Pipeline Status

Gap identified — not in PRD. The Pipeline Monitor screen shows a 'RUNNING: 64% COMPLETE' live progress indicator for each of the 12 pipelines. The PRD specifies 'status updates in <5s' for manual triggers (FR-23). The current stack has no mechanism for pushing status updates to the frontend — the React SPA would have to poll the API every few seconds, which is inefficient and creates unnecessary load.

Recommendation: Add Server-Sent Events (SSE) or WebSocket support to the FastAPI backend for pipeline status updates. FastAPI supports both natively. This is a small addition (a few endpoints) with large UX impact — the live pipeline progress view cannot work well without it. This should be added to the API contract in Week 1.

5.7 Summary Verdict Table

Technology Decision	PRD Recommendation	Research Verdict	Action Required
Frontend framework	React.js / Next.js	React SPA + Vite	Resolve to React SPA + Vite. Remove Next.js option.
Backend framework	FastAPI / Django REST	FastAPI only	Resolve to FastAPI only. Remove Django option.
Async pipelines	Celery	Confirmed correct	Use Celery chord for the 12+1 LLM barrier pattern.
Database	PostgreSQL + Redis + S3	Confirmed correct	No change needed.
Infrastructure V1	Docker + Kubernetes	Docker + Compose V1, K8s V1.1	Reduce to Docker Compose for MVP. K8s post-launch.
Real-time push	NOT IN PRD	SSE or WebSocket needed	Add to API contract. FastAPI supports natively.
LLM provider	Open Question Q1	Resolve immediately	Blocks all prompt engineering and cost modelling.

6. Target Customer Analysis

The PRD identifies four target user segments. This section validates those segments against market research and adds commercially prioritised sub-segments with sizing and acquisition approach.

6.1 Tier 1 — Immediate Priority (V1.0 MVP)

1. Mid-Market Financial Services (Banks, Asset Managers, Insurance)

Attribute	Detail
Why this segment	Financial services have the highest ERM adoption rate, the most structured risk frameworks (Basel III, IFRS 9, DORA), and the clearest ROI language (DV01 Delta, liquidity ratios, regulatory capital) — all visible in the UI artefacts
Evidence from artefacts	The Financial Liquidity Module in the prototypes (DV01 Delta, Macaulay Duration, Liquidity Coverage, Net Interest Margin, Basel III compliance) is purpose-built for this segment
Market size	Financial services accounts for the largest share of the \$6B+ ERM market. North America alone is \$2.41B (38% of total market)
Decision maker	CRO (Chief Risk Officer), CFO, Head of Risk Analytics
Pain point	Manual quarterly risk reporting, siloed departmental data, no AI correlation across financial sub-domains
Acquisition path	Fintech conferences (Sibos, Money20/20), CRO/CFO networks, direct outreach to mid-market banks (assets \$1B-\$50B) — not large enough for MetricStream but too complex for spreadsheets
Pricing sensitivity	Medium — will pay for compliance-grade outputs and investor-ready exports

2. Telecom Service Providers (Regional and National)

Attribute	Detail
Why this segment	Explicitly called out in PRD. SLA-linked domain monitoring is a genuine unmet need — telecom operations risk (network uptime, latency, regulatory compliance, supply chain for hardware) maps perfectly to the Module architecture
Evidence from artefacts	Pipeline monitor shows network/infrastructure domains. The five-level hierarchy supports telecom's layered operational risk structure
Market size	Telecom is one of the highest CAGR verticals in the ERM market due to cloud migration, 5G rollout risk, and supply chain dependencies
Decision maker	CTO, VP Network Operations, Head of Regulatory Affairs
Pain point	SLA breach prediction, network risk quantification for regulator reporting, supply chain visibility
Acquisition path	TelecomTechAsia, MEF conferences, direct outreach to Tier 2/3 telcos in APAC and Middle East (fastest growing ERM regions)
Pricing sensitivity	Low to medium — operational risk management has direct financial consequences (SLA penalties)

3. Conglomerates and Multi-Division Enterprises (Energy, Manufacturing, Logistics)

Attribute	Detail
Why this segment	The PRD explicitly targets Group CFO / Strategy Head at conglomerates. The consolidated enterprise-level AI report (synthesised from 12 modules) is the primary value proposition for this persona
Evidence from artefacts	AI Decision Hub's 'Ranked Risk Vectors' (Cybersecurity + Global Logistics + Fiscal Policy in one view) is exactly the cross-domain synthesis a Group CFO needs
Market size	Large enterprises with complex multi-domain risk are the highest-spending ERM segment. They are currently served by MetricStream or Archer at very high cost and long implementation times
Decision maker	Group CFO, Chief Strategy Officer, Group CRO
Pain point	No single view of cross-domain risk, investor/board reporting is manual and inconsistent, no AI-generated cross-domain correlation
Acquisition path	Direct sales to CFO/CRO offices of mid-large conglomerates (\$500M+ revenue), analyst relations with Gartner/Forrester to get on evaluation shortlists
Pricing sensitivity	Low — willing to pay significant amounts for a platform that replaces \$200k+ annual consulting bills for risk reporting

6.2 Tier 2 — Medium-Term Priority (V1.1 / V2.0)

4. SME Businesses (\$10M-\$500M revenue, any sector)

- The PRD lists 'SME Businesses / Business Owner / COO' as a target, and the spreadsheet displacement opportunity is enormous (59% still on spreadsheets)
- However, SMEs require a simplified UI and lower-touch onboarding — the current TBD2 design is executive-dense and complex, which may overwhelm an SME COO
- Recommended V2.0 feature: a simplified SME mode with 3-5 core modules vs the full 12, a streamlined dashboard, and self-service onboarding
- Pricing: \$500-\$2,000/month SaaS subscription. High volume, lower ACV.

5. Management Consulting Firms (Big 4, Boutique Risk Consultancies)

- Consulting firms advising enterprise clients on risk management could use TBD2 as their delivery platform — white-labelling or reseller model
- High-value: each consulting firm brings multiple enterprise client accounts
- Aligns with V2.0 multi-tenancy roadmap — one consulting firm, many client tenants

6.3 Geographies — Priority Order

Region	Market Share (2026)	Priority	Notes
North America	38% (\$2.41B)	TIER 1	Largest market, highest ERM maturity, densest enterprise concentration
Europe	29%	TIER 1	EU AI Act and GDPR creating urgent compliance demand
Asia-Pacific	23%	TIER 2	Fastest growing — APAC telcos and financial services are immediate targets
Middle East & Africa	10%	TIER 3	Emerging — relevant for V2.0 when multi-tenancy enables regional deployments

7. Critical Decisions Required Before Week 1 Coding

Based on the full analysis, the following decisions must be made by all three co-founders before any code is written. Each is blocking a different workstream.

#	Decision	Blocking	Owner	Deadline
D1	Confirm the exact list of 12 Modules and their Sub-Module/Group hierarchy	DB schema design, pipeline wrappers, all backend work	All three	Week 1 Day 1
D2	Resolve frontend framework: React SPA + Vite (confirmed recommendation)	Frontend architecture setup	Tech Lead + UI/UX	Week 1 Day 1
D3	Resolve backend framework: FastAPI only (confirmed recommendation)	Backend scaffold, API contract	Tech Lead	Week 1 Day 1
D4	Confirm LLM provider (Anthropic / OpenAI / Gemini)	Prompt engineering, API wrapper, cost modelling	All three	Week 1 Day 1
D5	Confirm deployment target: Cloud SaaS or on-premise	Infrastructure architecture, secrets management	All three	Week 1 Day 2
D6	Add SSE/WebSocket for pipeline status push to API contract	Pipeline Monitor live progress	Tech Lead + ML	Week 1 Day 3 (contract freeze)
D7	Define confidence scoring methodology (statistical model)	Confidence engine in Week 5-6	ML Partner	Week 3 at latest
D8	Specify Emergency Override, Force Recalc, Deploy New Watcher, Rollback Last Domain	Sprint 3-4 screen completeness	All three	Week 2

8. Unspecced UI Elements — Engineering Risk Register

The following 10 elements are visible in the design artefacts but have no corresponding Functional Requirements in the PRD. If specced mid-sprint, they will break the 8-week delivery timeline.

Element	Screen	Risk Level	Recommended Action
EMERGENCY OVERRIDE button	All screens (sidebar)	HIGH	Spec or remove before Week 1 Day 3
Force Recalc button	Sub-Module Detail	HIGH	Is this Admin-only? Full pipeline or local calc?
Rollback Last Domain	Pipeline Monitor	HIGH	Define what rollback means (DB state? pipeline output?)
Deploy New Watcher	Module Dashboard	MEDIUM	Spec or defer to V2.0 explicitly
Module Knowledge Base	Sub-Module Detail	MEDIUM	Where are files stored? Is it LLM context?
Report ID format (VL-AI-992-DELTA)	AI Decision Hub	MEDIUM	Define naming schema before storage design
Alert severity levels (Level 1-4)	Sub-Module Detail	MEDIUM	Define full severity schema beyond Green/Yellow/Red
Heatmap as tab vs separate screen	Module Dashboard	LOW	Decide route vs toggle before frontend routing
Processing rate (12.4GB/s)	Pipeline Monitor	LOW	Is this real instrumentation or decorative?
SSO placeholder scope	Settings (implied)	LOW	Config field only, or wired up to SAML?

9. Revised Technology Stack Recommendation

The following is the recommended production-grade stack for TBD2, with all research findings:

Layer	Component	Technology	Reason
Presentation	React SPA	React 18 + Vite + TailwindCSS + Recharts/D3	Best for auth-gated, interactive dashboards. Vite replaces CRA for 10x faster builds.
Presentation	State management	Zustand or TanStack Query	Lightweight, no Redux complexity. TanStack Query for server state.
Application	REST API	FastAPI (Python 3.11+)	Native async, 3000+ RPS, built-in OpenAPI docs, perfect for LLM relay.
Application	Async pipelines	Celery + chord pattern	12+1 LLM barrier/join maps exactly to Celery chord primitive.
Application	Real-time push	FastAPI SSE endpoints	Pipeline progress, alert streaming. Native to FastAPI. No extra infra.
AI	LLM integration	LiteLLM wrapper (model-agnostic)	Single interface for Anthropic/OpenAI/Gemini. Handles retry, rate limits, caching.
AI	Prompt management	DB-stored templates (PostgreSQL)	Version-controlled, Super Admin editable, required by PRD.
Data	Primary DB	PostgreSQL 15+	Recursive CTEs for hierarchy, JSONB for LLM response storage.
Data	Cache + broker	Redis 7+	Celery broker + LLM response cache + session cache.
Data	Object storage	MinIO (self-hosted S3-compatible)	Free, self-hosted, drop-in S3 replacement for PDF/PPT exports.
Infra V1.0	Deployment	Docker Compose	Reduce complexity for 8-week MVP. Migrate to Kubernetes post-launch.
Infra V1.1+	Deployment	Kubernetes (K8s)	Once load testing confirms need. Not required for V1.0 single tenant.
Security	Secrets	HashiCorp Vault or cloud secrets manager	LLM API keys never in code or env files.

10. Product Gaps & V2.0 Roadmap Recommendations

10.1 Missing from V1.0 (Should Reconsider)

- Real-time data ingestion (at minimum for high-value segments like financial services and telecom) — batch-only creates a credibility gap with enterprise customers who have real-time risk events
- Pricing model — no commercial model in the PRD. The team needs to define SaaS tiers before the first customer conversation
- Data privacy and residency policy — GDPR/CCPA compliance, data processing agreements. Enterprise customers will ask in procurement.
- At least one native ERP/ITSM integration — even read-only CSV/API import from SAP or ServiceNow would significantly lower onboarding friction

10.2 V2.0 Priorities (Confirm Alignment)

- Multi-tenancy — essential for SaaS scaling. Design the DB schema now with tenant isolation in mind even if V1.0 is single-tenant
- Agentic AI mode — autonomous pipeline triggering, alert escalation, and remediation suggestion based on threshold breaches
- Custom domain builder — self-service Module/Sub-Module/Group configuration without engineering involvement
- Native mobile app (iOS/Android) — executive dashboard access on mobile is expected by C-suite users
- Third-party integrations marketplace — SAP, ServiceNow, Salesforce, Jira, Slack/Teams alerts

Appendix: Glossary of Key Terms

Term	Definition
ERM	Enterprise Risk Management — the practice of identifying, assessing, and managing risks across an organisation
GRC	Governance, Risk and Compliance — the broader software category that includes ERM platforms
Two-tier LLM	TBD2 architecture: 12 parallel Module-level LLM calls (Tier 1) followed by one Enterprise-level synthesis call (Tier 2)
CAGR	Compound Annual Growth Rate — the rate at which a market grows year-over-year
Celery chord	Celery primitive for running a group of tasks in parallel then triggering a callback when all complete — the correct pattern for the 12+1 LLM sequencing requirement
SPC Chart	Statistical Process Control chart — time-series chart showing metric values relative to control limits
SSE	Server-Sent Events — a web standard for server-to-client push over HTTP, native to FastAPI
Vite	Modern JavaScript build tool, 10x faster than Create React App, recommended replacement
LiteLLM	Open-source Python library providing a unified interface to all major LLM APIs (Anthropic, OpenAI, Gemini), handles retries and rate limiting
MinIO	Free, open-source S3-compatible object storage that can run self-hosted in Docker

CONFIDENTIAL — For internal team use only. Not for external distribution.